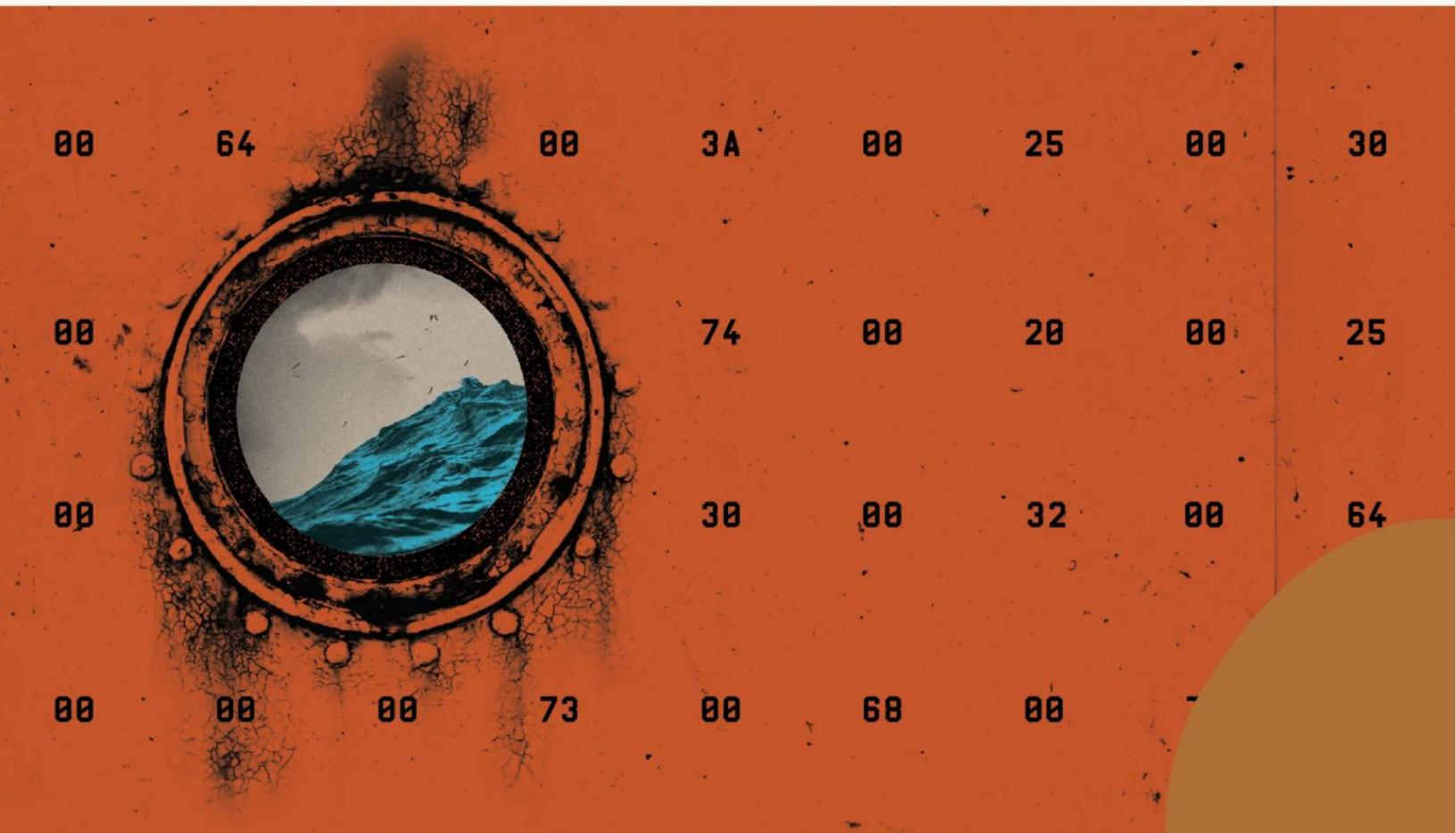


NotPetya – Maersk, 2017

*Análisis de un ciberataque real
y su impacto empresarial.*



Equipo 3

Melanie Alondra Alba Diez - 185583

Marco Antonio Amaya Saucedo - 040151

Juan Pablo Casanova De La Madrid - 175329

Samuel López Gómez - 177393

Jesús Israel Martínez Escobedo - 175325

Frieda María Ortiz López -184346

Manuel Darío Trejo Salazar - 174578

Índice

Introducción.....	3
Investigación y documentación	3
Línea del tiempo	3
Análisis técnico, impacto económico y estratégico	3
1. Contexto general del ataque.....	3
2. Tabla técnica del ataque	4
3. Evaluación del impacto - Modelo CIA.....	5
4. Cálculo del costo total del ciberataque – Marco Económico de Adrian Mizzi.....	6
Conclusiones	9
Referencias	10

Introducción

Investigación y documentación

Línea del tiempo



Análisis técnico, impacto económico y estratégico

1. Contexto general del ataque

El ataque NotPetya ocurrió el 27 de junio de 2017 y tuvo como principal objetivo a organizaciones en Ucrania, aunque posteriormente se propagó a empresas de distintos países. La propagación inicial se produjo mediante una actualización comprometida del software de contabilidad y declaración fiscal M.E.Doc, ampliamente utilizado por compañías ucranianas. Investigaciones concluyeron que los servidores de actualización del proveedor fueron comprometidos y utilizados para distribuir el malware como si se tratara de una actualización legítima, constituyendo un caso representativo de ataque a la cadena de suministro de software. Entre las organizaciones afectadas se encontraron ministerios, bancos, compañías eléctricas, medios de comunicación, medios de transporte y empresas estatales de infraestructura crítica, así como compañías internacionales como Maersk, Merck y TNT Express de FedEx (WIRED, 2018; SOS Intelligence, 2024).

Antes del incidente existían condiciones de seguridad que favorecieron la propagación del malware. Un elemento central fue la vulnerabilidad del protocolo SMBv1 de Microsoft. El 14 de marzo de 2017, Microsoft publicó el boletín de seguridad MS17-010, que corregía varias vulnerabilidades críticas de SMB utilizadas posteriormente por herramientas de explotación conocidas como *EternalBlue* y *EternalRomance* (CISA, 2018). La propia documentación de Microsoft indica que los sistemas que no habían instalado la actualización MS17-010 permanecían en un estado de alto riesgo frente a distintas familias de malware que explotaban dichas vulnerabilidades (CISA, 2018; Microsoft, 2018). Aunque el parche estuvo disponible más de tres meses antes de NotPetya, muchas organizaciones aún no lo habían aplicado en todos sus equipos.

Además de las vulnerabilidades técnicas, existían debilidades importantes en la arquitectura de seguridad. Las redes corporativas presentaban segmentación insuficiente, lo que permitió que el malware se propagara rápidamente entre equipos del mismo dominio. NotPetya no dependía únicamente de *EternalBlue*, también utilizó herramientas administrativas como *PsExec* y *WMIC*, junto con técnicas de robo de credenciales similares a *Mimikatz*, para desplazarse lateralmente una vez obtenía acceso inicial (CISA, 2018). Esto significa que incluso equipos correctamente parchados podían verse comprometidos si el atacante obtenía credenciales con privilegios elevados.

La propagación global destruyó prácticamente todos los controladores de dominio de Maersk. Sin embargo, un controlador ubicado en Ghana permaneció intacto porque un apagón había desconectado la oficina de la red durante el ataque. Este servidor conservaba una copia de la información esencial del dominio, incluidos usuarios, permisos y configuraciones. Su recuperación permitió reconstruir la infraestructura central a partir de un estado confiable y evitó que Maersk tuviera que crear desde cero su estructura de identidades y accesos. Debido a las limitaciones de conectividad, el disco que contenía la copia fue transportado físicamente desde Ghana hasta el Reino Unido para iniciar la restauración de los servicios globales (WIRED, 2018)

En cuanto a los factores humanos y organizacionales, la confianza depositada en las actualizaciones automáticas de un proveedor ampliamente utilizado resultó determinante. Las empresas asumían que las actualizaciones de M.E.Doc eran seguras, por lo que el malware ingresó a numerosas redes sin generar sospechas iniciales. También se evidenciaron deficiencias en la gestión de parches, en el control de privilegios administrativos y en el monitoreo de actividades anómalas dentro de la red corporativa. Diversos análisis posteriores señalaron que la combinación de un proveedor comprometido, sistemas sin actualizar, credenciales excesivamente privilegiadas y redes poco segmentadas creó un escenario idóneo para la propagación masiva del ataque (Microsoft, 2018).

Finalmente, aunque NotPetya se presentaba como un *ransomware*, múltiples investigaciones concluyeron que su diseño hacía imposible la recuperación de la información mediante el pago del rescate, debido a que la llave de descryptación era un string de caracteres generado aleatoriamente y no tenía la capacidad de recuperar nada al realizar el pago. Por ello, es considerado principalmente un *wiper* disfrazado de *ransomware*, cuyo objetivo principal era causar interrupción operativa y daño económico a gran escala, especialmente en organizaciones vinculadas a Ucrania (Microsoft, 2018; CSO, 2022).

2. Tabla técnica del ataque

Elemento	Descripción
Tipo de ataque	Malware destructivo o <i>wiper</i> disfrazado de <i>ransomware</i> . Aunque solicitaba USD 300 en bitcoin, su diseño no permitía recuperar la información mediante el pago.
Actor o grupo atacante	<i>Sandworm</i> (unidad de inteligencia militar rusa perteneciente a la Agencia Militar de Inteligencia Rusa) también conocido como Unit 74455.
Vector de entrada	Ataque a la cadena de suministro de M.E.Doc, software contable y fiscal desarrollado por Linkos Group y utilizado ampliamente en Ucrania. Los atacantes comprometieron su sistema de actualizaciones para distribuir NotPetya como una actualización legítima. En Maersk, el malware ingresó mediante un equipo de la oficina de Odesa que tenía instalado M.E.Doc.

Vulnerabilidad explotada	Vulnerabilidades de ejecución remota en SMBv1, principalmente CVE-2017-0144 , asociada con <i>EternalBlue</i> , y CVE-2017-0145 , relacionada con <i>EternalRomance</i> . También aprovechó credenciales administrativas obtenidas de la memoria de equipos infectados, por lo que podía comprometer sistemas actualizados accesibles mediante cuentas privilegiadas.
Etapas del ataque (MITRE ATT&CK)	Infiltración: El grupo ruso <i>Sandworm</i> comprometió los servidores de actualización de <i>M.E.Doc</i>, un software de contabilidad usado por empresas que operan en Ucrania; insertaron una puerta trasera en una actualización legítima al vulnerar los servidores de <i>M.E.Doc</i>. En Maersk, el punto de entrada fue una computadora en una oficina de Odesa, donde un empleado había instalado dicho software por requerimiento fiscal local. Ejecución: al ser activado el malware se disfrazó de <i>ransomware</i> pero en realidad era un <i>wiper</i>, con el objetivo de destruir, explotó vulnerabilidades SMBv1 <i>EternalBlue</i> y <i>EternalRomance</i> para ejecutarse remotamente en máquinas Windows sin parchar. Usó <i>Mimikatz</i> una herramienta de código abierto, para robar credenciales directamente de la memoria de equipos infectados. Propagación: Una vez las credenciales fueron robadas, el malware se replicó autónomamente por toda la red interna de Maersk, sobrescribiendo el MBR de cada máquina y eliminando la tabla maestra de archivos. Eliminó los respaldos en línea del Active Directory y comprometió alrededor de 150 controladores de dominio, eliminando posibilidades de restauración rápida por medios convencionales. Exfiltración: No hubo exfiltración real de datos. Tampoco intenciones de cobrar el rescate. NotPetya fue usado y diseñado como arma de destrucción, no como herramienta de robo de información.
Sistemas o servicios comprometidos	Aproximadamente 45,000 equipos y 4,000 servidores, cerca de 150 controladores de dominio, la red corporativa global, los sistemas de reservaciones y rastreo de contenedores y las operaciones de terminales portuarias.
Duración del incidente	El ataque comenzó el 27 de junio de 2017 y se propagó globalmente en cuestión de minutos. La red fue aislada durante las horas siguientes. La infraestructura central se reconstruyó en aproximadamente diez días, mientras que la recuperación de aplicaciones y configuraciones continuó durante cerca de dos meses.
Mecanismos de detección y respuesta	La detección inicial fue principalmente humana, al observarse reinicios y fallas simultáneas. Maersk ordenó apagar equipos y aislar su red global para frenar la propagación. Posteriormente reconstruyó servidores y estaciones de trabajo con apoyo de especialistas externos. La recuperación del Active Directory fue posible gracias a un controlador de dominio ubicado en Ghana que permaneció desconectado durante el ataque debido a un apagón. Después del incidente, Maersk reforzó la segmentación, el monitoreo, la continuidad operativa y la capacidad de respuesta ante incidentes.

3. Evaluación del impacto - Modelo CIA

Principio	Descripción del Impacto	Evidencia del caso
Confidencialidad	NotPetya obtenía credenciales almacenadas en la memoria de equipos infectados para suplantar usuarios y desplazarse lateralmente por la red. Se comprometió la confidencialidad de las cuentas utilizadas durante la propagación. Sin embargo, no existe evidencia pública de que el malware exfiltrara bases de datos, archivos corporativos o información de clientes de Maersk	Microsoft documentó que NotPetya utilizaba una herramienta similar a <i>Mimikatz</i> para extraer credenciales de sesiones activas y reutilizarlas mediante <i>PsExec</i> y <i>WMIC</i> (Microsoft Defender Security Research Team, 2017). Maersk declaró que no ocurrió una filtración de datos ni pérdida de información hacia terceros (A.P. Moller-Maersk, 2017)

Integridad	El impacto fue crítico porque NotPetya alteró estructuras esenciales de almacenamiento. Con privilegios elevados podía sobrescribir el <i>Registro de Arranque Maestro (MBR)</i> , cifrar la <i>Tabla Maestra de Archivos (MFT)</i> y cifrar archivos del sistema. Debido a que el identificador mostrado en la nota de rescate no permitía generar una clave válida, la información no podía recuperarse mediante el pago solicitado.	Microsoft confirmó que NotPetya podía sobrescribir el MBR y cifrar archivos de distintas extensiones (Microsoft Defender Security Research Team, 2017). Kaspersky concluyó que el identificador de instalación era generado aleatoriamente y no contenía la información necesaria para descifrar los discos, lo cual respaldaba su clasificación como <i>wiper</i> (Ivanov & Mamedov, 2017). Maersk tuvo que reconstruir aproximadamente 4,000 servidores y reinstalar 45,000 computadoras (Greenberg, 2018).
Disponibilidad	La infraestructura informática quedó inoperante, afectando reservas, seguimiento de carga y contenedores, comunicaciones internas y operaciones de terminales portuarias. Maersk Line, APM Terminals y Damco tuvieron que apagar sistemas y trabajar temporalmente mediante procedimientos manuales. En este caso la disponibilidad es el punto de más impacto ya que el objetivo del malware era únicamente destructivo.	Maersk reportó una interrupción significativa en sus negocios de transporte y logística. Las reservas se reanudaron parcialmente el 29 de junio y las operaciones de Maersk Line, Damco y APM Terminals se normalizaron gradualmente entre el 3 y el 9 de julio (A.P. Moller-Maersk, 2017). La reconstrucción principal tomó aproximadamente diez días y ciertas labores de reconstrucción de los sistemas continuaron cerca de dos meses (Greenberg, 2018).

4. Cálculo del costo total del ciberataque – Marco Económico de Adrian Mizzi

Para estimar el impacto económico de NotPetya en Maersk se utilizó como referencia la clasificación de costos directos e indirectos del marco económico de Adrian Mizzi. También se consideró la metodología de retorno de la inversión en seguridad, la cual permite comparar el costo de una medida de seguridad con las pérdidas que podría evitar (ENISA, 2012).

Maersk estimó que el incidente tuvo un impacto negativo de entre USD 250 y 300 millones. El reporte financiero del tercer trimestre de 2017 señala que la mayor parte de esta pérdida estuvo relacionada con la interrupción temporal del negocio durante julio y agosto, principalmente en Maersk Line. La cifra también comprendió costos para recuperar la operación y restablecer la confiabilidad de los servicios (A.P. Moller-Maersk, 2017, pp. 4-7).

Conversión a moneda nacional

Para expresar las cantidades en pesos mexicanos se utilizó el tipo de cambio promedio de 2017, estimado en \$18.91 MXN por dólar, calculado a partir de la serie histórica publicada por Banco de México (Banco de México, s. f.).

La conversión del impacto reconocido por Maersk es la siguiente:

$$(250 \text{ a } 300 \text{ Millones}) \text{ USD} \times 18.91 \text{ MXN/USD} = \$4,73 \text{ a } \$5,67 \text{ mil millones MXN}$$

Desglose estimado de los costos

Tipo de costo	Descripción	Estimación (MXN)
Pérdidas operativas	Interrupción de reservaciones, seguimiento de cargamentos y operaciones en terminales; reducción temporal de volúmenes; menor utilización de la capacidad y aumento de costos operativos durante la contingencia.	\$4,822.05 millones

Daños reputacionales	Afectación temporal a la confianza de clientes y socios comerciales por la imposibilidad de reservar o rastrear cargamentos. No existe una cuantificación pública independiente de pérdida de clientes, valor de marca o caída bursátil atribuible exclusivamente al ataque.	\$0 MXN cuantificables
Costos técnicos	Recuperación de sistemas, reconstrucción y reinstalación de servidores y computadoras, consultorías externas, horas extraordinarias, logística de emergencia y restauración de servicios tecnológicos.	\$850.95 millones
Costos legales o regulatorios	No se identificaron públicamente multas, sanciones regulatorias o indemnizaciones legales impuestas a Maersk como consecuencia directa del incidente.	\$0 MXN documentados
Pago de rescate o extorsión	NotPetya mostraba una solicitud de USD 300 en bitcoin por instalación afectada, equivalente aproximadamente a \$5,673 MXN. No existe evidencia pública de que Maersk efectuara dicho pago.	Solicitado: \$5,673 por instalación. Pagado: \$0 MXN
TOTAL ESTIMADO	Suma de las pérdidas operativas y los costos técnicos calculados para el escenario de mayor impacto reconocido por Maersk.	\$5,673 millones MXN

Cálculo de las pérdidas operativas

El reporte Q3 2017 indica que la mayor parte del impacto de USD 250–300 millones se debió a la interrupción del negocio. Por ello, se asigna el 85 % a pérdidas operativas (A.P. Moller–Maersk, 2017, pp. 6–7).

- Monto en USD: $\$300,000,000 \text{ USD} \times 85 \% = \$255,000,000 \text{ USD}$
- Conversión a MXN: $\$255,000,000 \text{ USD} \times \$18.91 \text{ MXN} = \$4,822,050,000 \text{ MXN}$

Las pérdidas operativas se estiman en \$4.82 mil millones MXN, incluyendo interrupción de reservaciones, seguimiento de carga y reducción de volúmenes. La empresa reportó una caída de 2.5 % en volúmenes y afectaciones en el desempeño operativo (A.P. Moller–Maersk, 2017, pp. 4 y 10).

Cálculo de los costos técnicos

El 15 % restante corresponde a costos técnicos de recuperación, incluyendo restauración de sistemas y operación de emergencia.

- Monto en USD: $\$300,000,000 \text{ USD} \times 15 \% = \$45,000,000 \text{ USD}$
- Conversión a MXN: $\$45,000,000 \text{ USD} \times \$18.91 \text{ MXN} = \$850,950,000 \text{ MXN}$

Los costos técnicos se estiman en \$850.95 millones MXN, derivados de la reconstrucción de aproximadamente 4,000 servidores y 45,000 equipos, reinstalación de sistemas y contratación de personal especializado (Greenberg, 2018).

Daños reputacionales

No existe una cifra pública verificable sobre pérdida de clientes o valor de marca, por lo que se registran como \$0 MXN cuantificables. Esto no implica que no hubiera un impacto en la reputación de la empresa, solamente que los datos financieros atribuibles al ciberataque no son públicos para hacer una estimación sin duplicar costos.

Costos legales y regulatorios

No se identificaron multas, sanciones o indemnizaciones públicas derivadas del ataque, por lo que se registran como \$0 MXN documentados.

Pago de rescate o extorsión

NotPetya solicitaba \$300 USD en bitcoin, equivalente a: $\$300 \text{ USD} \times \$18.91 \text{ MXN} = \$5,673 \text{ MXN}$. Este monto solicitado como rescate no se suma al costo total porque no hay evidencia de que Maersk lo haya pagado. Además, NotPetya funcionaba como malware destructivo, por lo que el pago no habría permitido recuperar la información (Greenberg, 2018).

Aplicación del modelo ROISI de Adrian Mizzi

La regla central de este marco dicta que el presupuesto preventivo en seguridad (E) siempre debe ser menor al costo total de la ruptura (L). Para este caso, la pérdida total tras el ataque fue de **\$5,673,000,000 MXN** y el costo estimado de la inversión preventiva fue de **\$1,045,571,720 MXN**, basado en el estándar sectorial del 0.2 % de los ingresos anuales.

Entonces, sustituyendo en la fórmula: $E < L$

- **$\$1,045,571,720 \text{ MXN} < \$5,673,000,000 \text{ MXN}$**

Esto demuestra que matemáticamente Maersk debió haber aprobado y ejecutado el presupuesto preventivo en ciberseguridad, ya que el gasto representaba apenas una fracción aproximada del **18.43 %** del daño financiero real que sufrió.

Porcentaje de la inversión respecto al daño: $(\$1,045,571,720 \div \$5,673,000,000) \times 100 = 18.43$

Fórmula del retorno de inversión en seguridad (ROISI)

Esta ecuación calcula el impacto real neto y determina cuánto capital se habría salvado o, para este caso en específico, cuánto capital se perdió por la decisión respecto a la inversión.

$$\text{Fórmula base: } ROISI = (ALE_0 - ALE_1) - C$$

Donde:

- **ALE_0** es la pérdida total tras el ataque.
- **C** es el costo estimado de la inversión preventiva.
- **ALE_1** es la pérdida residual esperada con seguridad.

Entonces:

$$ROISI = (\$5,673,000,000 - \$0) - \$1,045,571,720$$

$$ROISI = \$5,673,000,000 - \$1,045,571,720$$

$$ROISI = \$4,627,428,280 \text{ MXN}$$

Cálculo del ROISI porcentual

Para obtener el porcentaje exacto de rentabilidad que habría tenido la inversión preventiva:

$$ROISI_{\%} = \left(\frac{ROISI}{C} \right) \times 100$$

$$ROISI_{\%} = \left(\frac{\$4,627,428,280}{\$1,045,571,720} \right) \times 100$$

$$ROISI_{\%} = 4.4259 \times 100 = 442.59\%$$

Comparación sectorial

De acuerdo con el reporte financiero, los ingresos totales de A.P. Moller–Maersk en 2016 fueron de USD 27,646 millones. En el sector logístico y marítimo, durante 2016 y 2017, el gasto corporativo estimado en ciberseguridad rondaba aproximadamente el 0.2 % de los ingresos totales. Entonces:

- Presupuesto en USD: $\$27,646,000,000 \text{ USD} \times 0.002 = \$55,292,000 \text{ USD}$
- Conversión a MXN: $\$55,292,000 \text{ USD} \times \$18.91 \text{ MXN/USD} = \$1,045,571,720 \text{ MXN}$

Comparativa del costo frente al presupuesto

- **Costo de recuperación del ataque NotPetya:** \$5,673,000,000 MXN.
- **Presupuesto anual de ciberseguridad estimado:** \$1,045,571,720 MXN.
- **Proporción del impacto:** 5.43 veces.

El análisis comparativo demuestra que el costo de recuperación del ciberataque le costó a Maersk 5.43 veces más que el presupuesto que toda la corporación habría destinado a ciberseguridad durante un año entero. Este dato ratifica la viabilidad de la inversión preventiva.

Para las conversiones se utilizó el tipo de cambio FIX promedio de 2017, estimado en \$18.91 MXN por dólar, con base en la serie histórica publicada por Banco de México (Banco de México, s. f.). El impacto máximo de USD 300 millones fue reportado por Maersk en su informe financiero del tercer trimestre de 2017 (A.P. Moller–Maersk, 2017).

Conclusiones

Fallas críticas detectadas (Técnicas y Humanas)

La falla técnica más importante fue mantener una arquitectura de red completamente plana ya que la ausencia de segmentación permitió que el malware NotPetya utilizando el exploit EternalBlue se propagara lateralmente a través del protocolo SMBv1 en cuestión de minutos, infectando nodos globales de forma simultánea.

A nivel humano y de políticas, la falla más grave fue la dependencia absoluta de un único dominio de Active Directory sincronizado en tiempo real, sin contar con copias de seguridad fuera de línea. La empresa solo pudo recuperar su estructura de Active Directory gracias a un corte de energía no planeado en un servidor aislado en Ghana.

Buenas prácticas y políticas de mitigación

El daño se habría mitigado mediante la implementación de microsegmentación de red como VLANs restrictivas y listas de control de acceso para aislar los sistemas críticos, evitando que una infección en la red de contabilidad por donde ingresó el ataque en Ucrania alcanzara las terminales logísticas. Asimismo, el establecimiento de una política rigurosa de gestión de parches, auditorías de vulnerabilidades y la creación de respaldos inmutables para la infraestructura de identidad habrían garantizado una recuperación técnica en horas, y no en semanas.

Reflexión y recomendaciones para el entorno latinoamericano

El contexto de ciberseguridad en América Latina presenta retos presupuestales y operativos únicos ya que es sumamente común encontrar arquitecturas donde las redes corporativas y los sistemas de control industrial carecen de barreras físicas o lógicas.

Recomendaciones aplicables al contexto mexicano o latinoamericano:

1. **Segmentación estricta y control de tráfico:** Configurar correctamente los conmutadores (*switches*) y firewalls existentes para aislar los departamentos, bloqueando protocolos de comunicación innecesarios entre ellos como el uso indiscriminado de SMB o RDP.

2. **Arquitectura de Resiliencia:** Establecer políticas de copias de seguridad de la regla "3-2-1" 3 copias, 2 medios distintos, 1 fuera de línea, garantizando que al menos un respaldo sea físicamente inaccesible desde la red principal.
3. **Planes de Respuesta a Incidentes (IRP):** Desarrollar manuales de contingencia que asuman que la red caerá por completo, capacitando al personal para operar de forma manual es decir hacer los procesos en papel mientras los equipos de soporte técnico ejecutan la reconstrucción, minimizando el lucro cesante.

Referencias

A.P. Moller–Maersk. (2017a). *Interim Report Q3 2017*.

<https://investor.maersk.com/static-files/1226cd7b-d1b4-4281-b42c-5f032b0e1595>

A.P. Moller–Maersk. (2017b). *Annual Report 2016*.

<https://investor.maersk.com/static-files/a31c7bbc-577a-49df-9214-aef2d649a9f5>

Banco de México. (s. f.). *Sistema de Información Económica: tipo de cambio FIX*.

<https://www.banxico.org.mx/tipcamb/llevarTiposCambioAction.do?idioma=sp>

ENISA. (2012). *Introduction to Return on Security Investment: Helping CERTs assessing the cost of (lack of) security*.

<https://www.enisa.europa.eu/sites/default/files/publications/Return%20On%20Security%20Investment.pdf>

Gartner. (2021). *IT Key Metrics Data 2021: Industry Measures—Transportation*. Gartner Research.

Greenberg, A. (2018, 22 de agosto). *The untold story of NotPetya, the most devastating cyberattack in history*. WIRED.

<https://www.wired.com/story/notpetya-cyberattack-ukraine-russia-code-crashed-the-world/>

IANA Research y Artico Search. (2023). *Security Budget Benchmark Report: Key findings*.

<https://www.iansresearch.com/resources/press-releases/detail/new-research-from-ians-and-artico-search-reveals-cybersecurity-budgets-increased-just-6-for-2022-2023-cycle>

<https://adrianmizzi.com/ijns-2010-v10-n1-p18-24.pdf>

https://www.cisa.gov/sites/default/files/publications/data_backup_options.pdf